

Jak działa cały system — od formularza do zamkniętej sprzedaży

Trzy wtyczki WordPressa, trzy bazy danych, jeden proces. Skąd biorą się dane, co się z nimi dzieje i gdzie kończą. Część I — dla wszystkich. Część II — dla osób technicznych.

W jednym zdaniu

Klient wypełnia formularz na stronie, system sprawdza jego firmę w rejestrach, przygotowuje ofertę PDF z cenami ze sklepu, przydziela sprawę handlowcowi, wysyła klientowi ofertę e-mailem i pilnuje terminów kontaktu — aż sprzedaż zostanie wygrana albo przegrana.

Robią to trzy osobne wtyczki. Każda ma własną bazę i własne zadanie, a rozmawiają ze sobą wyłącznie krótkimi komunikatami. Taki podział ma konkretny skutek praktyczny: awaria generatora ofert nie zatrzymuje przyjmowania zapytań, a wyłączenie jednej wtyczki nie kasuje danych pozostałych.

Trzy wtyczki, trzy zadania

MP Lead Intake — przyjmuje i sprawdza zapytania z formularza. MP Offer Builder — liczy i generuje oferty PDF. MP Sales Workflow — prowadzi sprzedaż: przydział handlowca, statusy, e-maile, przypomnienia, historia.

CZĘŚĆ I — dla wszystkich

Krok 1. Klient wypełnia formularz

Na stronie stoi formularz zapytania: dane firmy, numer NIP, kraj, e-mail, czego klient potrzebuje. Klient nie musi mieć konta ani się logować.

Zanim cokolwiek zostanie zapisane, system sprawdza formularz: czy pola są wypełnione, czy numer NIP w ogóle może istnieć i czy formularza nie wysłał automat. Dopiero potem powstaje zapytanie w bazie.

Krok 2. System weryfikuje firmę

Numer NIP jest sprawdzany w oficjalnych rejestrach — czy firma istnieje i czy jest czynnym podatnikiem. To ma wpływ na późniejszy podatek w ofercie: firma z Unii Europejskiej z ważnym numerem VAT może dostać ofertę bez podatku (odwrotne obciążenie), a pozostali dostają stawkę krajową.

Sprawdzenie idzie do zewnętrznych rejestrów, więc bywa wolne albo chwilowo

niedostępne. Dlatego dzieje się w tle, już po zapisaniu zapytania — klient nie czeka przy formularzu, aż rejestr odpowie, a niedostępność rejestru nie gubi zapytania.

Krok 3. Powstaje oferta

Handlowiec dobiera pozycje z katalogu sklepu, ilości i wariant cenowy. System pobiera aktualne ceny, nalicza rabaty i właściwy podatek, a potem generuje ofertę PDF z własnym numerem — takim, który nie powtórzy się nigdy.

Poprawka oferty nie nadpisuje poprzedniej. Powstaje nowa wersja pod tym samym numerem, a stara zostaje w historii. Dzięki temu zawsze da się pokazać, co dokładnie klient dostał w zeszłym tygodniu.

Krok 4. Sprawa dostaje właściciela

Gdy zapytanie wpada do systemu, powstaje proces sprzedażowy — jeden na klienta, nawet jeśli później powstanie kilka ofert. System sam wybiera handlowca po kraju i języku klienta. Gdy nikt nie pasuje albo osoba jest nieobecna, sprawa trafia do managera — nie zawisa nigdzie bez opiekuna.

Krok 5. Klient dostaje ofertę

Po zatwierdzeniu oferty klient dostaje e-mail z odnośnikiem do PDF, a handlowiec — powiadomienie, że proces ruszył. Odnośnik jest podpisany kryptograficznie i ważny 14 dni; podmiana choćby jednego znaku w adresie go unieważnia.

Klient nie loguje się nigdzie, żeby pobrać ofertę. Nie ma też dostępu do panelu — widzi wyłącznie swój jeden dokument.

Krok 6. System pilnuje terminów

Do procesu zakładane są automatyczne przypomnienia o kontakcie: na trzeci i na siódmy dzień. Jeśli w międzyczasie sprawa ruszy do przodu, przypomnienie samo się wycofa — zadanie wykonuje się tylko wtedy, gdy proces nadal stoi w tym samym miejscu, w którym był przy planowaniu.

Krok 7. Domknięcie i historia

Handlowiec przesuwając proces przez statusy aż do wygranej albo przegranej. Każda zmiana trafia do dziennika: kto, kiedy, z czego na co. Dziennik zostaje także po zakończeniu sprzedaży — i przeżywa nawet usunięcie samego procesu.

Kto co widzi

- Handlowiec — wyłącznie procesy przypisane do siebie.
- Manager sprzedaży — procesy swojego zespołu.
- Administrator — wszystko.
- Klient — nic w panelu; dostaje wyłącznie e-mail i jeden podpisany odnośnik do własnej oferty.

Próba otwarcia cudzego procesu przez ręczne poprawienie adresu w przeglądarce kończy się komunikatem „nie znaleziono”. Celowo nie „brak uprawnień” — ta druga odpowiedź potwierdzałaby, że taki proces w ogóle istnieje.

Co robi system, a czego nie robi

- Robi: zakłada proces, wybiera handlowca, wysyła oferty i powiadomienia, planuje i wycofuje przypomnienia, zapisuje historię.
- Nie robi: nie kontaktuje się z klientem za handlowca, nie negocjuje ceny, nie zmienia statusu sprzedaży sam z siebie i nie zamyka procesu bez decyzji człowieka.

CZĘŚĆ II — dla osób technicznych

Architektura w skrócie

Trzy wtyczki WordPressa, trzy niezależne zestawy tabel, komunikacja wyłącznie przez haki WordPressa (do_action). Żadna wtyczka nie czyta tabel drugiej przez klucze obce — granice modułów biegną po zdarzeniach, nie po bazie.

- MP Lead Intake (LP.1) — BD-3: wp_mp_leads, wp_mp_offers, wp_mp_activity_log. Pipeline 11 działań.
- MP Offer Builder (LP.2) — BD-2: wp_mp_ob_offers, wp_mp_ob_offer_items, wp_mp_ob_offer_versions, wp_mp_ob_offer_templates, wp_mp_ob_offer_activity_log. Pipeline 11 działań.
- MP Sales Workflow (LP.3) — BD-1: wp_mp_sw_flow, wp_mp_sw_tasks, wp_mp_sw_notifications, wp_mp_sw_activity, wp_mp_sw_events. Pipeline 9 działań.

Każda wtyczka pracuje tym samym wzorcem: żądanie przechodzi przez kolejne działy, w każdym dziale pary Agent+Krytyk (1:1), a po dziale bramka jakości. Odrzucenie przez krytyka zatrzymuje cały przebieg, zanim cokolwiek zostanie zapisane.

Zdarzenia między wtyczkami

- mp_lead_created(\$lead_id, \$payload) — emituje LP.1 po zapisaniu leada (Dział 11). Słucha LP.3: zakłada proces sprzedaży i przydziela handlowca.
- mp_offer_created(\$offer_id, \$payload) — emituje LP.2 po finalizacji oferty (Dział 11, po COMMIT). Słucha LP.3: przedstawia proces na status „oferta w przygotowaniu”.
- mp_offer_approved — LP.3 ma gotowy nasłuch, ale w tej wersji NIKT go jeszcze nie emituje. To kontrakt na przyszłość: zatwierdzenie oferty jako osobna decyzja biznesowa w LP.2. Dopóki go nie ma, pełną drogę uruchamia mp_offer_created.

Zdarzenie niesie wyłącznie identyfikatory — nigdy adresu e-mail odbiorcy, ścieżki pliku PDF ani gotowego odnośnika. To reguła bezpieczeństwa, nie oszczędność: gdyby adres przychodził w komunikacie, dowolna inna wtyczka na tej instalacji mogłaby wywołać ten sam hak z własnym adresem i przekierować ofertę do siebie. LP.3 czyta adres i ścieżkę z baz LP.1 i LP.2 po identyfikatorze.

Skąd biorą się dane i gdzie trafiają

1. Wejście — formularz (LP.1)

Źródło: publiczny formularz na stronie, jeden punkt AJAX dla niezalogowanych.

Zabezpieczenia wejścia: token CSRF, sprawdzenie Origin/Referer, pole-pułapka na automaty, limit liczby żądań i limit rozmiaru, biała lista dopuszczalnych pól.

Trafia do: wp_mp_leads — dane firmy, NIP, kraj, e-mail, segment. Adres IP jest zapisywany w postaci skróconej (anonimizacja) i po 90 dniach kasowany przez zadanie cykliczne.

2. Weryfikacja rejestrowa (LP.1, w tle)

Źródło: zewnętrzne rejestry podatkowe. Wywoływane po zapisie leada, poza żądaniem klienta — dostępność cudzego serwisu nie może decydować o tym, czy zapytanie w ogóle zostanie przyjęte.

Trafia do: kolumny statusu weryfikacji przy leadzie. Wynik decyduje później o mechanizmie podatkowym oferty.

3. Budowa oferty (LP.2)

Źródła: dane klienta z leada (LP.1), ceny i pozycje z katalogu WooCommerce, szablon oferty z `wp_mp_ob_offer_templates`.

Trafia do: `wp_mp_ob_offers` (nagłówek, kwoty w groszach, mechanizm podatkowy, ścieżka PDF, skrót SHA-256 pliku), `wp_mp_ob_offer_items` (pozycje), `wp_mp_ob_offer_versions` (pełna historia wersji — tylko dopisywanie). Sam plik PDF łąduje w katalogu prywatnym w `uploads`, poza zasięgiem przeglądarki.

4. Proces sprzedażowy (LP.3)

Źródła: identyfikator leada ze zdarzenia, a po nim — pojedynczy odczyt z bazy: dane procesu, role i zespół handlowca, dane klienta z `wp_mp_leads`, dane oferty z `wp_mp_ob_offers`.

Trafia do: `wp_mp_sw_flow` (jeden wiersz na leada), `wp_mp_sw_tasks` (przypomnienia), `wp_mp_sw_notifications` (kolejka e-mail z gotową treścią), `wp_mp_sw_activity` (dziennik), `wp_mp_sw_events` (rejestr obsłużonych zdarzeń).

5. Wyjście — e-mail i PDF

Adres odbiorcy pochodzi z bazy leadów, nie z komunikatu. Odnośnik do PDF jest generowany na miejscu: podpis HMAC-SHA256 nad parą (uchwyt oferty, termin ważności), kluczem `MP_SW_LINK_KEY` z `wp-config.php`.

Wysyłka rusza dopiero PO zatwierdzeniu transakcji zapisu. Kolejność jest istotna: e-maila nie da się cofnąć, więc nie może wyjść przed zapisem, który mógłby się jeszcze wycofać.

Trzy reguły, na których stoi LP.3

Jeden odczyt, jedna transakcja, zero sieci

W obsłudze jednego żądania: dokładnie jeden odczyt z bazy (Dział 2 pobiera całą potrzebną migawkę naraz), dokładnie jedna transakcja zapisu (Dział 8) i zero wywołań sieciowych. Sprawdzenia uprawnień nie dokładają zapytań — korzystają z tej samej migawki.

To nie jest optymalizacja dla samej wydajności. Odczyty rozsypane po działach dawały ryzyko, że dwa działły zobaczą inny stan tego samego procesu; jedna transakcja gwarantuje, że przy błędzie w połowie zapisu nie zostaje proces bez zadania albo zadanie bez procesu.

Zdarzenie z właściwego kanału

Każdy typ zdarzenia jest związany z kanałem, którym wolno mu przyjść: `lead.created` i `offer.approved` tylko z haka systemowego, `task.due` tylko z `crona`, `status.change` i `dashboard.view` z panelu. Macierz jest domknięta domyślnie — typ, którego na niej nie ma, nie ma żadnego dozwolonego źródła.

Bez tej reguły zalogowany handlowiec mógł wysłać żądanie typu „oferta zatwierdzona” z cudzym numerem leada i wypuścić firmowego maila do cudzego klienta — własnym, ważnym tokenem i własnym uprawnieniem.

To samo zdarzenie obsłużone raz

Każde zdarzenie ma identyfikator, a tabela rejestru ma na nim więz unikalności. Powtórka tego samego zdarzenia — np. dwa równoległe wywołania `crona` — odbija się o indeks i zwraca wynik pierwszego przebiegu, zamiast wykonać pracę drugi raz. Klient nie dostanie dwóch identycznych ofert.

Bezpieczeństwo — co zostało zamknięte

- Wejście HTTP wyłącznie dla zalogowanych. Jedyny publiczny punkt to podpisany odnośnik do oferty — broni się kryptografią, bo klient nie ma konta.
- Sięgnięcie po cudzy proces zwraca 404, a nie 403. Odpowiedź nie potwierdza istnienia obiektu, więc przelatywanie identyfikatorów niczego nie zdradza.
- Dane z formularza (autor: osoba anonimowa) są zabezpieczane przy wypisywaniu w panelu i przy budowie nagłówek e-mail — znaki końca wiersza w temacie wiadomości są odrzucane, nie „czyszczone po cichu”.
- Metadane profilu z prefiksem `mp_` może zmieniać tylko użytkownik z uprawnieniem `promote_users` — handlowiec nie przepisze sobie zespołu ani kraju.
- Bezpiecznik wysyłki: 200 wiadomości na godzinę, potem kolejka staje i czeka na decyzję administratora. Nadmiarowa wysyłka to jedyna szkoda w tym systemie, której nie da się cofnąć.

- Odmowy nie ujawniają reguł ani treści zapytania — w odpowiedzi jest tylko kod ze słownika (MP3-Exxx), a szczegóły trafiają do dziennika technicznego serwera, nie do bazy.

Dane osobowe i retencja

- Adres IP z formularza — zapisany w postaci skróconej, kasowany po 90 dniach.
- Rejestr zdarzeń LP.3 — czyszczony po 90 dniach.
- Dziennik aktywności — nie jest czyszczony nigdy; to on odtwarza historię procesu. Nie zawiera adresu e-mail ani IP: przy powiadomieniu zapisywana jest rola odbiorcy („klient”, „handlowiec”), nie jego adres.
- Treści wysłanych e-maili — usuwane razem z procesem (twardy więz ON DELETE CASCADE), bo w treści siedzą dane klienta. Ślad samej wysyłki zostaje w dzienniku.
- Żądanie usunięcia danych — anonimizuje dane klienta w procesie i w powiadomieniach, zachowując wiersze. Obsługiwane przez mechanizm RODO WordPressa (Narzędzia → Usuń dane osobowe).

Co trzeba ustawić poza kodem

Trzy rzeczy, bez których system uruchomi się bez błędu, ale nie zadziała poprawnie:

1. Stałe `MP_HASH_PEPPER` i `MP_SW_LINK_KEY` w `wp-config.php` (min. 32 bajty losowe). Bez klucza linków wtyczka celowo wstrzyma wysyłkę powiadomień do klientów, zamiast wysyłać martwe odnośniki.
2. Poczta: SMTP oraz rekordy SPF, DKIM i DMARC dla domeny. Bez nich oferty lądują w spamie albo są odrzucane.
3. Cron systemowy zamiast `wp-cron` „przy okazji odwiedzin”, z zablokowanym dostępem do `wp-cron.php` z zewnątrz. Bez tego przypomnienia nie odpalą się w porę, a kolejka e-mail stoi.

Gdzie są szczegóły

Pełna checklista wdrożeniowa z gotowymi blokami konfiguracji nginx i Apache: plik `docs/WDROZENIE.md` w katalogu wtyczki oraz „instrukcja instalacji (techniczna)” dołączona do tej dokumentacji. Schematy: nietechniczny (proces w pięciu krokach), techniczny (pipeline 9 działów) i schemat bazy danych BD-1.